DFD Level 0 (Context Diagram) — Explanation

CloudGuard IoT | Team ZeroTrace | Companion to `03-System-Behavior/DFD-Level-0.png`

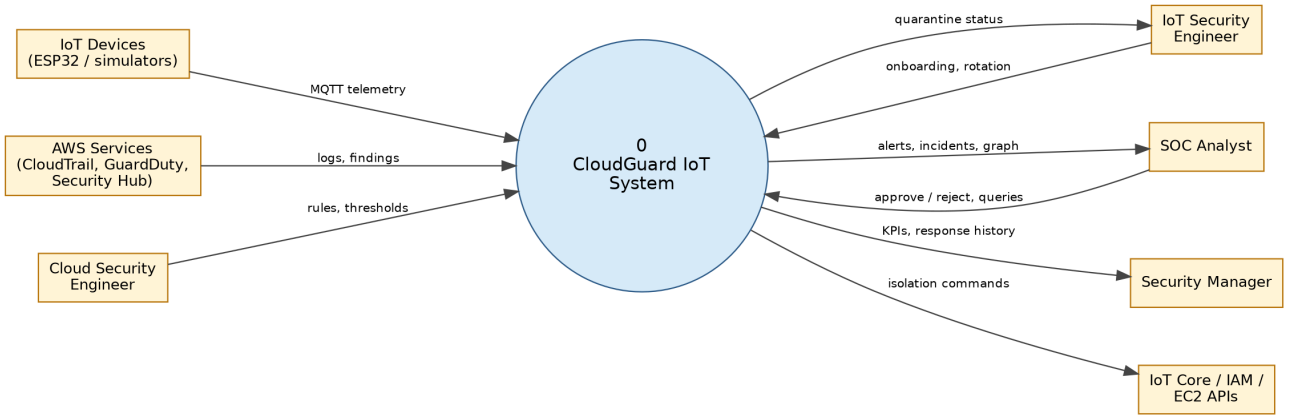


Figure: DFD Level 0 (context diagram)

1. Purpose

The Level 0 DFD (context diagram) shows CloudGuard IoT as one single process and the world around it. It answers three questions: who or what talks to the system, what data goes in, and what data comes out. Nothing about the internal design is shown here; that is the job of Level 1.

The system is drawn as one circle, labelled **0 — CloudGuard IoT System**, because the platform behaves as one security brain: it takes telemetry from both the IoT and cloud domains and returns decisions, alerts and containment actions.

2. Notation

Symbol	Meaning
Circle	The system as a single process
Rectangle	External entity (a person or system outside the boundary)
Labelled arrow	A data flow, named by the data it carries

There are no data stores at this level. Stores belong inside the system boundary and appear in Level 1.

3. External Entities

Entity	Type	Role in the context
IoT Devices (ESP32 / simulators)	System	Source of MQTT telemetry; 3 physical ESP32 boards and 10–20 Python simulators
AWS Services (CloudTrail, GuardDuty, Security Hub)	System	Source of cloud audit logs and security findings
IoT Security Engineer	Human	Onboards devices, rotates certificates, receives quarantine status
Cloud Security Engineer	Human	Maintains detection rules and thresholds
SOC Analyst	Human	Reviews alerts and incidents, approves or rejects isolation
Security Manager	Human	Reads posture, KPIs and response history
IoT Core / IAM / EC2 APIs	System	Receive isolation commands that change policies, certificates, roles and security groups

4. Data Flows

4.1 Inputs to the system

Flow	From	Description
MQTT telemetry	IoT Devices	Connect, publish and subscribe activity of each device over mutual TLS. Reaches the platform as AWS IoT Core logs
Logs, findings	AWS Services	CloudTrail API events, GuardDuty findings and Security Hub findings
Onboarding, rotation	IoT Security Engineer	Requests to register a device, issue a certificate, rotate or reinstate it
Rules, thresholds	Cloud Security Engineer	New or changed detection rules and risk thresholds (change-controlled)
Approve / reject, queries	SOC Analyst	Decision on a proposed isolation, plus read requests for incidents, scores and the graph

4.2 Outputs from the system

Flow	To	Description
Alerts, incidents, graph	SOC Analyst	Alert queue, incident timelines, explainable score breakdowns and the Security Graph
KPIs, response history	Security Manager	MTTD, time-to-isolate, isolation success rate and the audit log of responses
Isolation commands	IoT Core / IAM / EC2 APIs	Quarantine policy swap, certificate deactivation, deny policy on a role, quarantine security group
Quarantine status	IoT Security Engineer	Which devices are quarantined and when they are ready for rotation

5. How to Read the Diagram (reference scenario)

1. An IoT device starts publishing at about 20 times its normal rate and tries topics outside its policy. This enters the system as **MQTT telemetry**.
2. At the same time CloudTrail and GuardDuty report suspicious activity on the related identity. This enters as **logs, findings**.
3. Inside the system the two domains are scored and correlated into one incident (detail in Level 1).
4. The system sends **Alerts, incidents, graph** to the SOC Analyst and, because the score is Critical, sends **Isolation commands** to the AWS APIs automatically.
5. The IoT Security Engineer sees the **Quarantine status**, and later submits **Onboarding, rotation** to recover the device.
6. The Security Manager reviews the outcome through **KPIs, response history**.

6. Boundary and Assumptions

- **Inside the boundary:** every component the team builds or configures: normalizers, behavioral monitor, Risk Engine, correlation, decision engine, isolation and recovery Lambdas, evidence collection, API and dashboard.
- **Outside the boundary:** the devices themselves, AWS-managed services acting as data sources (CloudTrail, GuardDuty, Security Hub), and the AWS control-plane APIs that carry out isolation.
- **IoT Core / IAM / EC2 APIs** appear only as an output target. They are the means of enforcement, not a data source for this diagram.
- Device telemetry reaches the system through AWS IoT Core logging, so the platform never receives raw device traffic directly.

7. Traceability

Context flow	Related requirement
MQTT telemetry, Logs, findings	FR-03, FR-04 (collection and normalization)
Onboarding, rotation	FR-01, FR-02, FR-16
Rules, thresholds	FR-05, FR-07 (change-controlled thresholds)
Approve / reject	FR-10, FR-17
Alerts, incidents, graph	FR-14, FR-17
Isolation commands	FR-11, FR-12
KPIs, response history	FR-15, OBJ-S3

8. Link to Level 1

The single process 0 is decomposed into eight processes (P1–P8) in the Level 1 diagram. Every flow on this page appears there, either as a flow into or out of one of those processes.